SMART INDIA HACKATHON 2026

PRAMAAN

Secure Evidence Vault

Problem Statement ID – SIH26190

Problem Statement Title – Secure Digital Document Management System for law enforcement agencies, courts and investigative departments

Theme – Cybersecurity and Blockchain

PS Category – Software

Team ID – SIH-UPES-2026-T250

Team Name (Registered on portal) – leet



Organisation: Ministry of Home Affairs · National Crime Records Bureau (NCRB)

Separate the trust. Verify before release. Record every access.

Standalone, fully on-premise · no dependency on any external system

leet

PRAMAAN — SECURE EVIDENCE VAULT

SMART INDIA HACKATHON 2026

Proposed Solution (Idea / Prototype) | How it addresses the problem | Innovation and uniqueness of the solution

PRAMAAN — THE EVIDENCE LIFECYCLE, FROM THE RUNNING PROTOTYPE

Today this is a paper register and a shared drive with no way to prove anything was never altered. Below is what replaces it — six real screens from the build.

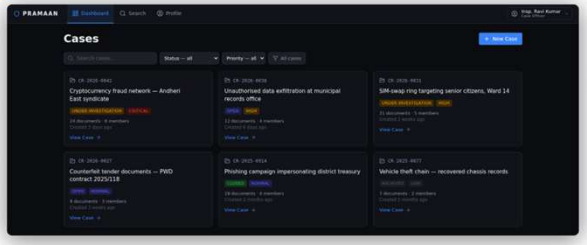
SIGN IN — MFA ENFORCED

1



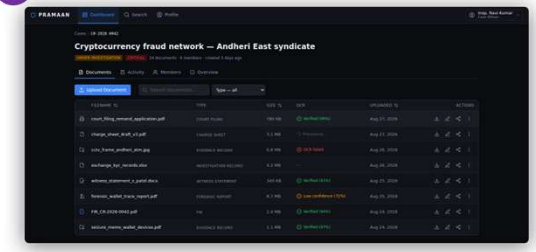
CASE-SCOPED DASHBOARD

2



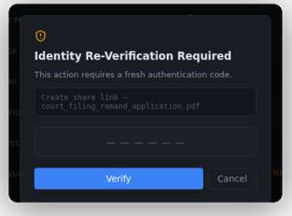
UPLOAD, OCR & VERIFY

3



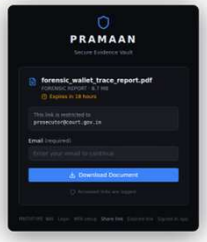
STEP-UP MFA TO SHARE

4



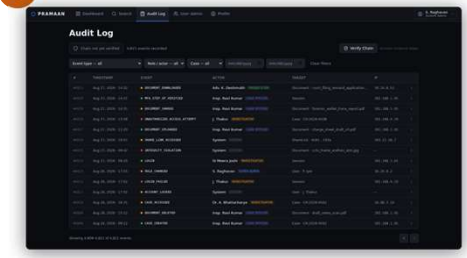
RECIPIENT OPENS VIA OTP

5



EVERY STEP AUDIT-LOGGED

6



One rule holds all of it together: evidence is never released if its integrity cannot be verified.

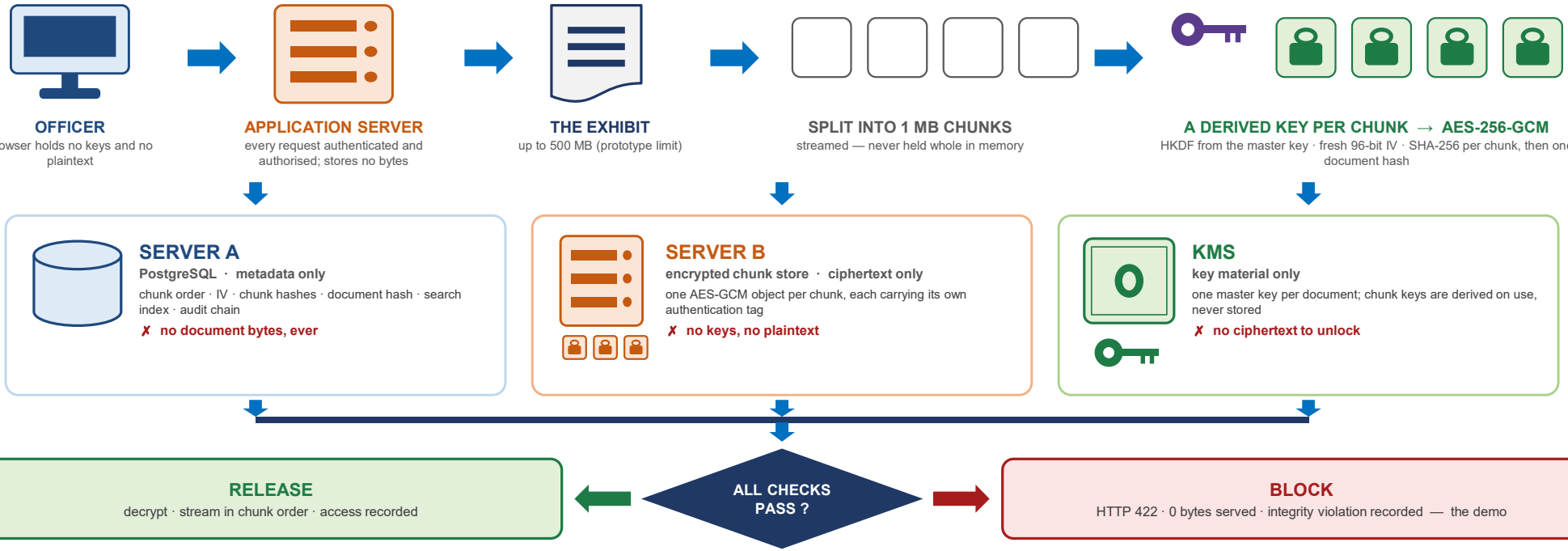
leet

TECHNICAL APPROACH

SMART INDIA HACKATHON 2026

Technologies to be used | Methodology and process for implementation (Flow Charts / Images / working prototype)

SECURITY ARCHITECTURE — one document, end to end



Nothing is streamed before every chunk hash, every authentication tag and the document hash have passed.

React SPA · Flask REST API · PostgreSQL · encrypted chunk store · key management service · Tesseract OCR | AES-256-GCM · HKDF-SHA256 · SHA-256 · Ed25519 · bcrypt · TOTP · JWT

leet

FEASIBILITY AND VIABILITY

SMART INDIA HACKATHON 2026

Analysis of the feasibility of the idea | Potential challenges and risks | Strategies for overcoming these challenges

FEASIBILITY — TECHNICAL, OPERATIONAL AND FINANCIAL, PROVEN IN A 9-DAY BUILD

DAYS 1–2	DAYS 3–4	DAY 5	DAY 6	DAYS 7–8	DAY 9
Auth · MFA · RBAC	Chunked crypto ★	Audit chain	Search · OCR	Signatures · sharing	Tamper demo

TECHNICAL FEASIBILITY

- Open-source stack — React, Flask, PostgreSQL, Tesseract
- A working prototype, not slideware — every screen is real
- Crypto from audited libraries only — nothing hand-rolled
- Commodity hardware — standard servers, no special infrastructure

OPERATIONAL FEASIBILITY

- Standalone, on-premise — no external dependency
- Minimal footprint — one backend, one frontend, Postgres only
- Role-based from day one — six roles, one admin console
- Clear path to production — Vault, MinIO are drop-in swaps

FINANCIAL FEASIBILITY

- Zero licensing cost — every component is open source
- No mandatory cloud spend — on-premise by default
- No specialised hardware budget required
- Audited libraries avoid an in-house crypto audit cost

THREAT MODEL — what the prototype defends against, and what it does not

DEFENDED IN THE PROTOTYPE

- Compromise of the metadata server alone
- Compromise of the encrypted chunk store alone
- A database administrator reading evidence content
- Stolen credentials without the second factor
- Cross-case and unauthorised API access
- Modification of stored ciphertext
- Retroactive edits to the audit trail

PARTIALLY ADDRESSED

- Compromise of the application server
- Compromise of the KMS or a document master key
- A stolen live authenticated session
- Backup media holding metadata, ciphertext or keys
- A privileged account rewriting the whole audit chain

OUT OF SCOPE FOR THE PROTOTYPE

- Full root or operating-system compromise of a host
- Physical access to the machines
- A compromised cryptographic library
- Formally verified implementation
- Production disaster recovery and high availability
- Certified PKI / e-signature deployment

PRAMAAN does not claim compromise is impossible. It limits the impact of partial compromise, and refuses to release evidence it cannot verify.

leet

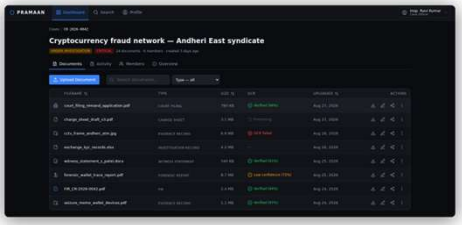
IMPACT AND BENEFITS

SMART INDIA HACKATHON 2026

Potential impact on the target audience | Benefits of the solution (social, economic, environmental, etc.)

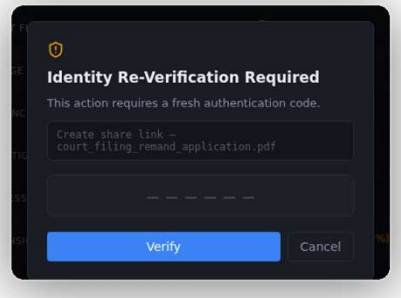
ONE APP, ROLE-SCOPED — WHAT EACH PERSON ACTUALLY SEES

CASE OFFICER



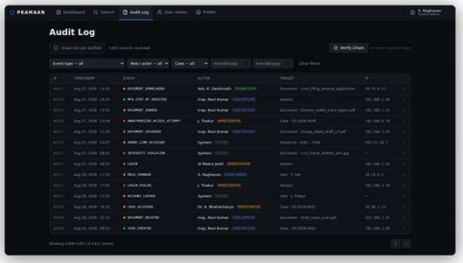
Uploads evidence into an indexed, encrypted case file — replaces station registers and shared drives.

COURTS & PROSECUTORS



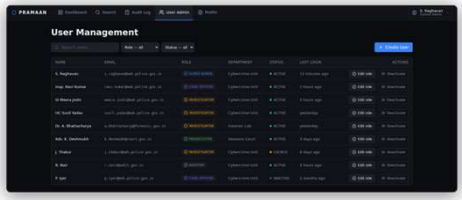
Receive an exhibit only through a step-up-verified, recipient-bound, time-limited share.

AUDITORS & OVERSIGHT



Recompute the hash-chained audit log on demand; verification names the first event that fails.

SYSTEM ADMIN



Roles and access are managed centrally — six roles, one console, every change logged.

WHAT WE WILL MEASURE — stated as targets; figures reported from the prototype, not claimed now

Blast radius of a single compromised host

Neither storage server on its own yields a readable document.

Response to an integrity failure

0 bytes served, HTTP 422, and an audit event recorded.

Retrieval and verification time

To be benchmarked at 10 MB, 100 MB and 500 MB.

leet

RESEARCH AND REFERENCES

SMART INDIA HACKATHON 2026

Details / Links of the reference and research work

CRYPTOGRAPHIC STANDARDS WE IMPLEMENT

NIST SP 800-38D
AES-GCM mode, IV construction and tag length — our per-chunk cipher. nvlpubs.nist.gov

RFC 5869 — HKDF
Extract-and-expand key derivation; the basis of our per-chunk keys. rfc-editor.org/rfc/rfc5869

RFC 8032 — Ed25519
Deterministic EdDSA signatures; no per-signature nonce to reuse. rfc-editor.org/rfc/rfc8032

RFC 6238 — TOTP
Time-based one-time passwords for the second factor. rfc-editor.org/rfc/rfc6238

NIST SP 800-57 Part 1 Rev.5
Key-management lifecycle — generation, storage, rotation, destruction.

SECURITY ENGINEERING REFERENCES

OWASP ASVS 4.0
The verification checklist our access-control and crypto-storage requirements map to. owasp.org

OWASP Top 10 (2021)
Broken access control and cryptographic failures drove the 404-not-403 scoping rule.

NIST SP 800-92
Log management guidance behind the audit event schema and retention design.

Saltzer & Schroeder (1975)
Least privilege and complete mediation — why authorisation is re-checked per request.

Threat-model sources
Each threat on slide 4 traces to one of the above rather than to intuition.

TECHNOLOGY & PRIOR ART STUDIED

pyca/cryptography
AESGCM, HKDF and Ed25519 primitives — audited implementations, no custom crypto. cryptography.io

PostgreSQL 16
Full-text search, GIN indexes and transaction-scoped advisory locks. postgresql.org/docs

Tesseract OCR + Indic tessdata
Fully offline OCR with Devanagari, Tamil, Telugu, Bengali and Gujarati packs.

MinIO · HashiCorp Vault
Studied as production swap-ins behind our chunk-store and KMS interfaces.

Ollama · sentence-transformers
Studied for the future on-premise AI layer — not part of the core system.

HOW THE RESEARCH SHAPED THE BUILD

OUR OWN DESIGN RECORD

- Eleven feature plans plus architecture, security, API and cross-cutting edge-case documents.
- Every cryptographic and access-control decision was written down and threat-modelled before implementation.

WHAT THE READING CHANGED

- SP 800-38D → per-chunk HKDF keys instead of one key per file, so an IV cannot repeat under a key.
- OWASP ASVS → 404 instead of 403 on case-scoped resources, so existence is never confirmed.
- NIST SP 800-92 → audit events carry actor, action, case, document and result, not just a message.

FUTURE SCOPE — AI OUTSIDE THE EVIDENCE BOUNDARY

- Context Retrieval — semantic search over a read-only derived index, filtered to cases the officer can already access.
- Document Summarisation — a local model drafts summaries on-premise; no evidence leaves the network.
- Secure Session Playground — the ephemeral sandbox summarisation runs in, wiped on close, nothing retained unless saved.
- The AI layer reads a derived copy and can never modify original evidence.